

Microsoft Certified: Security Operations Analyst Associate

Course

Defend against cyberthreats with Microsoft's security operations platform

---

Module 1

Mitigate threats using Microsoft Defender XDR

Modules in this learning path

COURSE 2

Mitigate threats using Microsoft Defender XDR

Introduction

Microsoft Defender XDR is a unified pre- and post-breach enterprise defense suite that natively coordinates detection, prevention, investigation, and response across endpoints, identities, email, and applications to provide integrated protection against sophisticated attacks.

With the integrated Microsoft Defender XDR solution, security professionals can coordinate the threat signals that each of these products receive and determine the full scope and impact of the threat. How the threat entered the environment, what it's affecting, and how it's currently impacting the organization.

You're a Security Operations Analyst working at a company that implemented Microsoft Defender XDR solutions, including Defender for Endpoint, Defender for Identity, and Microsoft Defender for Cloud Apps.

You need to see related alerts across all the solutions as one incident to see the incident's full impact and do a root cause investigation. The Microsoft Defender portal is a unified view of incidents and actions taken.

Use the Microsoft Defender portal

The Microsoft Defender portal (https://security.microsoft.com/) is a specialized workspace designed to meet the needs of security teams. These solutions are integrated across Microsoft 365 services and provide actionable insights to help reduce risks and safeguard your digital estate.

You can investigate the alerts that affect your network, understand what they mean, and collate evidence associated with the incidents so that you can devise an effective remediation plan.

The Home page shows many of the common cards that security teams need. The composition of cards and data is dependent on the user's role. Because the Microsoft Defender portal uses role-based access control, different roles see cards that are more meaningful to their day-to-day jobs.

This at-a-glance information helps you keep up with the latest activities in your organization. The Microsoft Defender portal brings together signals from different sources to present a holistic view of your Microsoft 365 environment.

The Microsoft Defender portal combines protection, detection, investigation, and response to email, collaboration, identity, device, and app threats, in a central place.

This single pane of glass brings together functionality from existing Microsoft security portals, like the Microsoft Defender portal and the Office 365 Security & Microsoft Purview portal. The Microsoft Defender portal emphasizes quick access to information, simpler layouts, and bringing related information together for easier use. It includes:

Microsoft Defender for Office 365 - Microsoft Defender for Office 365 helps organizations secure their enterprise with a set of prevention, detection, investigation and hunting features to protect email, and Office 365 resources.

Microsoft Defender for Endpoint - Delivers preventative protection, post-breach detection, automated investigation, and response for devices in your organization.

Microsoft Defender XDR - is part of Microsoft's Extended Detection and Response (XDR) solution that uses the Microsoft 365 security portfolio to automatically analyze threat data across domains, and build a picture of an attack on a single dashboard.

Microsoft Defender for Cloud Apps - Is a comprehensive cross-SaaS and PaaS solution bringing deep visibility, strong data controls, and enhanced threat protection to your cloud apps.

Microsoft Defender for Identity - Is a cloud-based security solution that uses your on-premises Active Directory signals to identify, detect, and investigate advanced threats, compromised identities, and malicious insider actions directed at your organization.

Microsoft Defender Vulnerability Management - Delivers continuous asset visibility, intelligent risk-based assessments, and built-in remediation tools to help your security and IT teams prioritize and address critical vulnerabilities and misconfigurations across your organization.

Microsoft Defender for IoT - Operational Technology (OT) involves the specialized hardware and software used to monitor and control physical processes in critical sectors such as manufacturing, utilities, pharmaceuticals, and more. Microsoft Defender for IoT, available within the Microsoft Defender portal, is designed to secure OT environments.

Microsoft Sentinel - Integrate Microsoft Defender XDR with Microsoft Sentinel to stream all Defender XDR incidents and advanced hunting events into Microsoft Sentinel and keep the incidents and events synchronized between the Azure and Microsoft Defender portals.

The More resources option in the portal provides a list of these related portals:

Portal	Description
Microsoft Purview portal	Manage your compliance needs across Microsoft 365 services using integrated solutions for information governance, classification, case management, and more.
Microsoft Entra ID	Manage your organization's identities. Set up multifactor authentication, track user sign-ins, edit company branding, and more.
Microsoft Entra ID Protection	Detect potential vulnerabilities affecting your organization's identities. Investigate suspicious incidents related to your organization's identities and set up automated responses to resolve them.
Azure Information Protection	Configure and manage the Azure Information Protection client and scanner to automatically classify and protect your organization's email and docs. Use reports to monitor label usage and identify sensitive info that should be protected.
Microsoft Defender for Cloud	Protect your data centers and get advanced threat protection for your Azure and non-Azure workloads in the cloud and on premises. Secure your Azure services fast with autoprovisioned, native protection.

Map Microsoft Defender XDR Unified role-based access control (RBAC) permissions

All permissions listed within the Microsoft Defender XDR Unified RBAC model align to existing permissions in the individual RBAC models. Once you activate the Microsoft Defender XDR Unified RBAC model the permissions and assignments configured in your imported roles replace the existing roles in the individual RBAC models.

This article describes how existing roles and permissions in Microsoft Defender for Endpoint, Microsoft Defender Vulnerability Management, Microsoft Defender for Office 365, Microsoft Defender for Identity, and Microsoft Entra roles map to the roles and permission in the Microsoft Defender XDR Unified RBAC model.

Important

Microsoft recommends that you use roles with the fewest permissions. This helps improve security for your organization. Global Administrator is a highly privileged role that should be limited to emergency scenarios when you can't use an existing role.

Map Microsoft Defender XDR Unified RBAC permissions to existing RBAC permissions

Important

Starting February 16, 2025, the Microsoft Defender XDR Unified RBAC model will be the default permissions model for new Microsoft Defender Endpoint tenants. These new tenants won't have the capability to export roles and permissions from the current model. Defender for Endpoint tenants with roles and permissions assigned or exported prior to this date will maintain their current roles and permissions configuration

Starting March 2, 2025, new Microsoft Defender for Identity tenants will also have the Unified RBAC model as their default permissions model. They won't be able to export roles and permissions from the current model. Existing Defender for Identity tenants maintain their current roles and permissions configuration.

Use the tables in the following sections to learn more about how your existing individual RBAC role definitions map to your new Microsoft Defender XDR Unified RBAC roles:

Map Defender for Endpoint and Defender Vulnerability Management permissions

Map Defender for Office 365 permissions to the Microsoft Defender XDR Unified RBAC permissions

Map Microsoft Defender for Identity permissions

Microsoft Entra Global roles access

Map Defender for Endpoint and Defender Vulnerability Management permissions to the Microsoft Defender XDR RBAC permissions

Defender for Endpoint and Defender Vulnerability Management permissions	Microsoft Defender XDR Unified RBAC permission
View data - Security operations	Security operations \ Security data \ Security data basics (read)
View data - Defender Vulnerability Management	Security posture \ Posture management \ Vulnerability management (read)
Alerts investigation	Security operations \ Security data \ Alerts (manage)
Active remediation actions - Security operations	Security operations \ Security data \ Response (manage)
Active remediation actions - Defender Vulnerability Management - Exception handling	Security posture \ Posture management \ Exception handling (manage)
Active remediation actions - Defender Vulnerability Management - Remediation handling	Security posture \ posture management \ Remediation handling (manage)
Active remediation actions - Defender Vulnerability Management - Application handling	Security posture \ Posture management \ Application handling (manage)
Defender Vulnerability management – Manage security baselines assessment profiles	Security posture \ posture management \ Security baselines assessment (manage)
Live response capabilities	Security operations \ Basic live response (manage)
Live response capabilities - advanced	Security operations \ Advanced live response (manage) Security operations \ Security data \ File collection (manage)
Manage security settings in the Security Center	Authorization and settings \ Security settings \ Core security settings (manage) Authorization and settings\Security settings \ Detection tuning (manage)
Manage portal system settings	Authorization and settings \ System setting (Read and manage)
Manage endpoint security settings in Microsoft Intune	Not supported - this permission is managed in the Microsoft Intune admin center

Map Defender for Office 365 permissions to the Microsoft Defender XDR Unified RBAC permissions

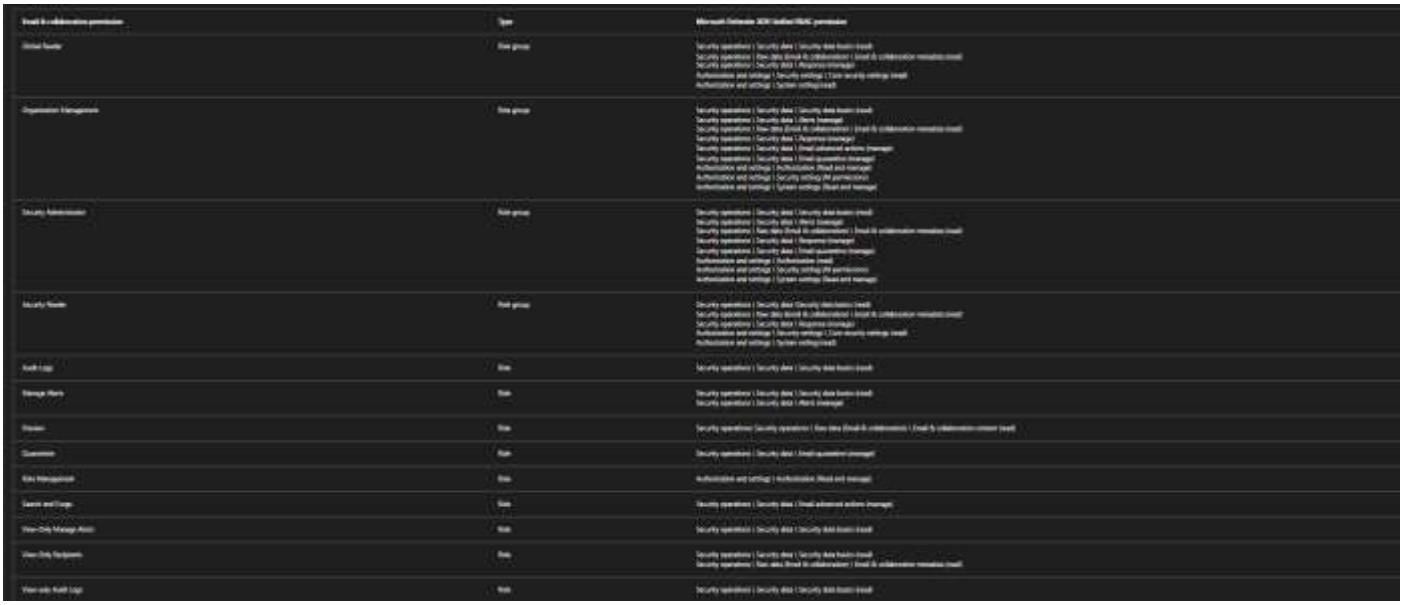
Use the following tables to learn how your existing Email & collaboration and protection-related Exchange Online permissions for Defender for Office 365 map to the new Microsoft Defender XDR Unified RBAC permissions:

Email & collaboration permissions mapping

Exchange Online permissions mapping

Email & collaboration permissions mapping

You configured Email & collaboration permissions in the Defender portal at https://security.microsoft.com/emailandcollabpermissions.



Exchange Online permissions mapping

You configured protection-related Exchange Online permissions in the Exchange admin center (EAC) at https://admin.exchange.microsoft.com/#/adminRoles.

Exchange Online permission	Type	Microsoft Defender XDR Unified RBAC permission
Hygiene Management	Role group	Security operations \ Security data \ Email quarantine (manage) Authorization and settings \ Security settings \ Core security settings (manage) Authorization and settings \ Security settings \ Detection tuning (manage)
Organization Management	Role group	Security operations \ Raw data (email & collaboration) \ Email & collaboration metadata (read) Authorization and settings \ Security settings \ Core security settings (manage) Authorization and settings \ Security settings \ Detection tuning (manage) Authorization and settings \ System settings (Read and manage)
Security Administrator	Role group	Authorization and settings \ Security settings \ Detection tuning (manage) Authorization and settings \ System settings (Read and manage)
View-Only Organization Management	Role group	Authorization and settings \ Security settings (Read-only) Authorization and settings \ System settings (Read-only)
Tenant AllowBlockList Manager	Role	Authorization and settings \ Security settings \ Detection tuning (manage)
View-only Recipients	Role	Security operations \ Raw data (email & collaboration) \ Email & collaboration metadata (read)

Map Microsoft Defender for Identity permissions to the Microsoft Defender XDR Unified RBAC permissions

Defender for Identity permission	Defender XDR Unified RBAC permission
MDI admin	Security operations \ Security data \ Security data basics (read) Security operations \ Security data \ Alerts (manage) Authorization and settings \ Authorization (Read and manage) Authorization and settings \ Security setting (All permissions) Authorization and settings \ System settings (Read and manage)
MDI user	Security operations \ Security data \ Security data basics (read) Security operations \ Security data \ Alerts (manage) Authorization and settings \ Security setting (All permissions) Authorization and settings \ System setting (read)
MDI viewer	Security operations \ Security data \ Security data basics (read) Authorization and settings \ Security settings \ Core security settings (read) Authorization and settings \ System setting (read)

Note

Defender for Identity experiences will also adhere to permissions granted from Microsoft Defender for Cloud Apps. For more information, see Microsoft Defender for Identity role groups. Exception: If you have configured Scoped deployment for Microsoft Defender for Identity alerts in Microsoft Defender for Cloud Apps, these permissions do not carry over. You need to explicitly grant the Security operations \ Security data \ Security data basics (read) permissions for the relevant portal users.

Map Microsoft Defender for Cloud Apps permissions to the Microsoft Defender XDR Unified RBAC permissions

Important

App Governance supports Microsoft Entra roles as described in Roles in app governance for Microsoft Defender for Cloud Apps and does not support the roles defined in the integration of Defender for Cloud Apps with unified RBAC.

Once you activate the Defender for Cloud Apps integration with Microsoft Defender XDR Unified RBAC, the following roles, configured through built-in scoped roles in Defender for Cloud Apps, will no longer be supported: App/instance admin, User group admin, Cloud Discovery global admin, and Cloud Discovery report admin.

Defender for Cloud Apps permission	Defender XDR Unified RBAC permission
Local Global administrator	Security operations \ Security data \ Security data basics (read) Security operations \ Security data \ Alerts (manage) Authorization and settings \ Authorization (all permissions) Authorization and settings \ Security settings (all permissions) Authorization and settings \ System settings (all permissions)
Local Security operator	Security operations \ Security data \ Security data basics (read) Security operations \ Security data \ Alerts (manage) Authorization and settings \ Authorization (read) Authorization and settings \ Security setting (all permissions) Authorization and settings \ System setting (read)
Local Security reader	Security operations \ Security data \ Security data basics (read) Authorization and settings \ Authorization (read) Authorization and settings \ Security settings \ Security settings (read) Authorization and settings \ System settings (read)
Local Compliance administrator	Security operations \ Security data \ Security data basics (read) Security operations \ Security data \ Alerts (manage) Authorization and settings \ Authorization (read) Authorization and settings \ Security settings \ Security settings (all permissions) Authorization and settings \ System settings (read)

Microsoft Entra Global roles access

Users assigned with Microsoft Entra global roles may also have access to the Microsoft Defender portal.

Use this table to learn about the permissions assigned by default for each workload (Defender for Endpoint, Defender Vulnerability Management, Defender for Office and Defender for Identity) in Microsoft Defender XDR Unified RBAC to each global Microsoft Entra role.



Note

By activating the Microsoft Defender XDR Unified RBAC model, users with Security Reader and Global Reader roles can access Defender for Endpoint data.

Manage incidents

Microsoft Defender XDR provides a cross-domain threat correlation and purpose-driven portal to investigate threats. Incidents are based on related alerts created when a malicious event or activity is seen on your network. Individual alerts provide valuable clues about an on-going attack. However, attacks typically employ various vectors and techniques to carry out a breach. Piecing individual clues together can be challenging and time-consuming.

An incident is a collection of correlated alerts that make up the story of an attack. Microsoft Defender XDR automatically aggregates malicious and suspicious events that are found in different device, user, and mailbox entities in the network. Grouping related alerts into an incident gives security defenders a comprehensive view of an attack.

For instance, security defenders can see where the attack started, what tactics were used, and how far the attack has gone into the network. Security defenders can also see the scope of the attack. Like how many devices, users, and mailboxes were impacted, how severe the impact was, and other details about affected entities.

If enabled, Microsoft Defender XDR can automatically investigate and resolve the individual alerts through automation and artificial intelligence. Security defenders can also perform more remediation steps to resolve the attack straight from the incidents view.

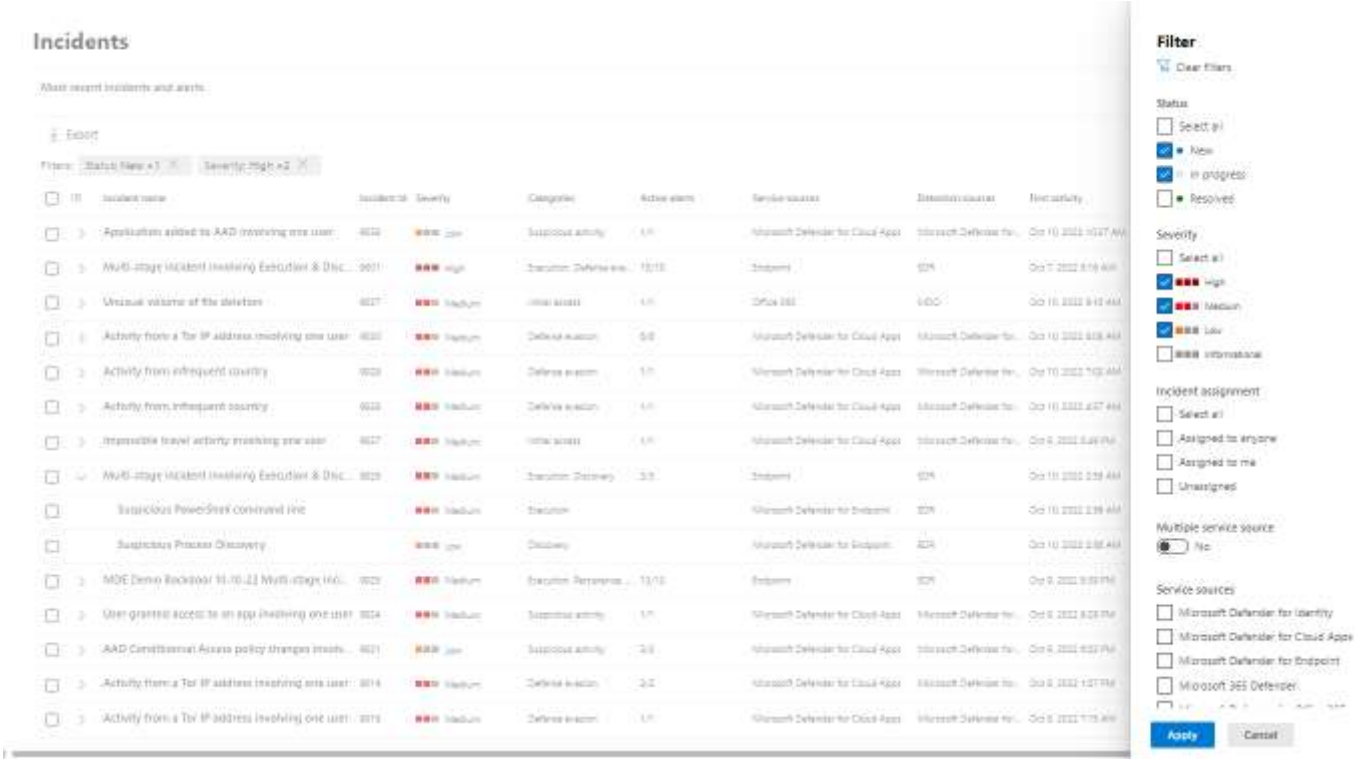
Incidents from the last 30 days are shown in the incident queue. From here, security defenders can see which incidents should be prioritized based on risk level and other factors.

Security defenders can also rename incidents, assign them to individual analysts, classify, and add tags to incidents for a better and more customized incident management experience.

Prioritize incidents

Microsoft Defender XDR applies correlation analytics and aggregates all related alerts and investigations from different products into one incident. Microsoft Defender XDR also triggers unique alerts on activities that can only be identified as malicious given the end-to-end visibility that Microsoft Defender XDR has across the entire estate and suite of products. This view gives your security operations analyst the broader attack story, which helps them better understand and deal with complex threats across the organization.

The Incidents queue shows a collection of flagged incidents from across devices, users, and mailboxes. It helps you sort through incidents to prioritize and create an informed cybersecurity response decision.



By default, the queue in the Microsoft Defender portal displays incidents seen in the last 30 days. The most recent incident is at the top of the list so that you can see it first.

The incident queue exposes customizable columns that give you visibility into different characteristics of the incident or the contained entities. This deeper layer of information helps you make an informed decision regarding the prioritization of incidents to handle.

For more clarity at a glance, automatic incident naming generates incident names based on alert attributes such as the number of endpoints affected, users affected, detection sources, or categories. The automatic naming allows you to quickly understand the scope of the incident.

Available filters

Status

You can choose to limit the list of incidents shown based on their status to see which ones are active or resolved.

Severity

The severity of an incident is indicative of the impact it can have on your assets. The higher the severity, the bigger the impact and typically requires the most immediate attention.

Incident assignment

You can choose to show alerts that are assigned to you or the alerts handled by automation.

Multiple service source

Select No (default), or yes to enable.

Service sources

Filter to only see incidents that contain alerts from different sources. Sources include: Microsoft Defender for Endpoint, Microsoft Cloud App Security, Microsoft Defender for Identity, Microsoft Defender for Office 365.

Tags

Filter on assigned tags. Any assigned Tags will appear once you select the Type tag name field.

Multiple category

You can choose to see only incidents that have mapped to multiple categories and can thus potentially cause more damage.

Categories

Choose categories to focus on specific tactics, techniques, or attack components seen.

Entities

Filter on entity name or ID.

Data sensitivity

Some attacks focus on targeting to exfiltrate sensitive or valuable data. By applying a filter to see if sensitive data is involved in the incident, you can quickly determine if sensitive information has been compromised. And if a compromise is found you can prioritize a response to those incidents. This filtering ability is only applicable if Microsoft Purview Information Protection is turned on.

Device group

Filter by defined device groups.

OS platform

Limit the incident queue view by operating system.

Classification

Filter incidents based on the set classifications of the related alerts. The values include true alerts, false alerts, or not set.

Automated Investigation state

Filter incidents by the status of the automated investigation.

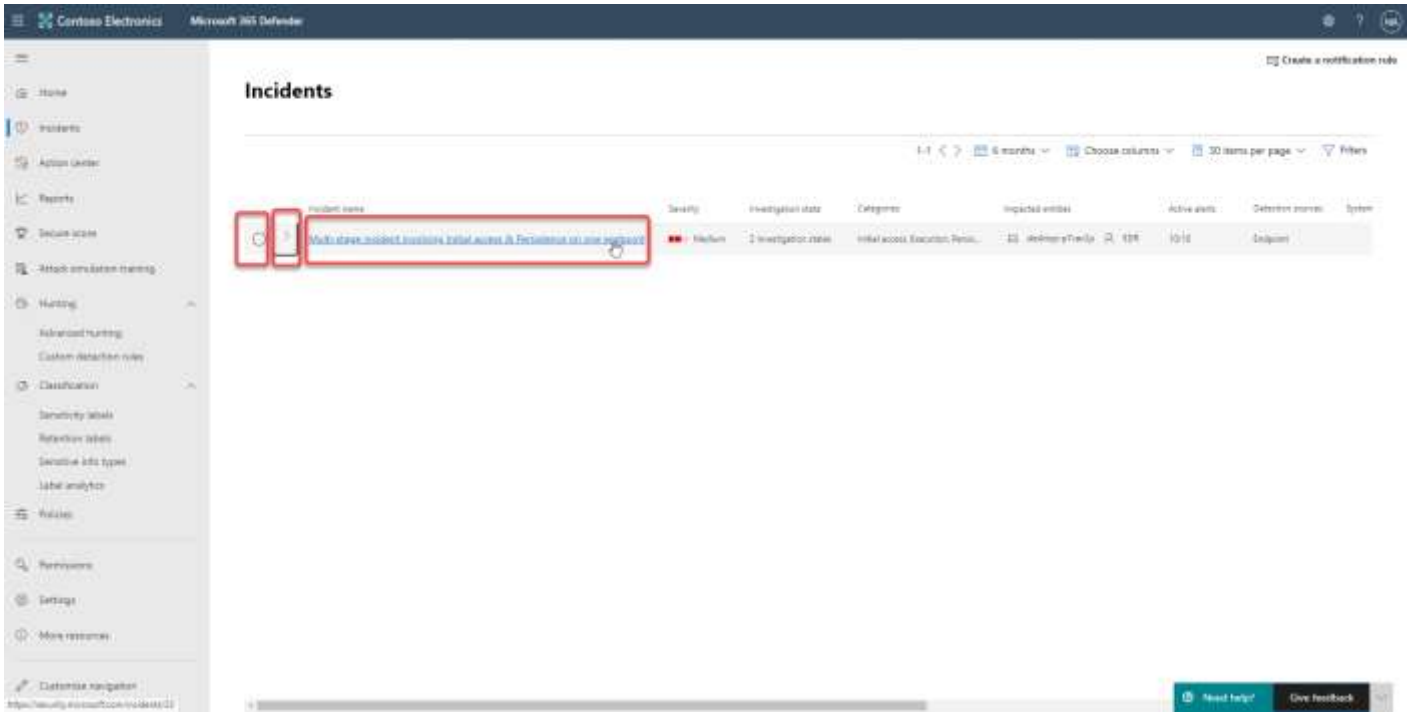
Associated Threat

Selecting the Type associated threat field will allow you to enter threat information, and bring up previous search criteria.

Preview incidents

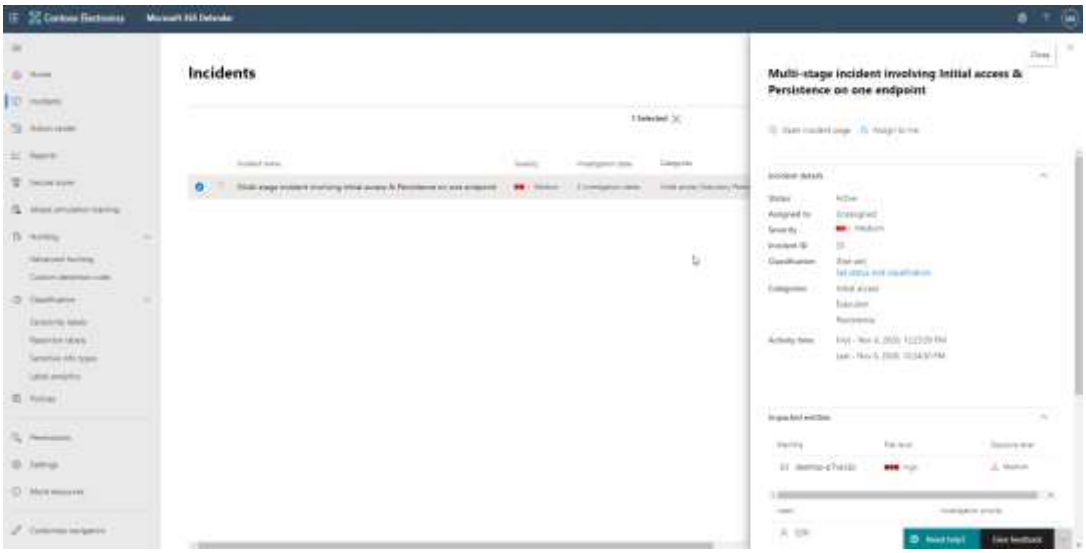
The portal pages provide preview information for most list-related data.

In this screenshot, the three highlighted areas are the circle, the greater than symbol, and the actual link.



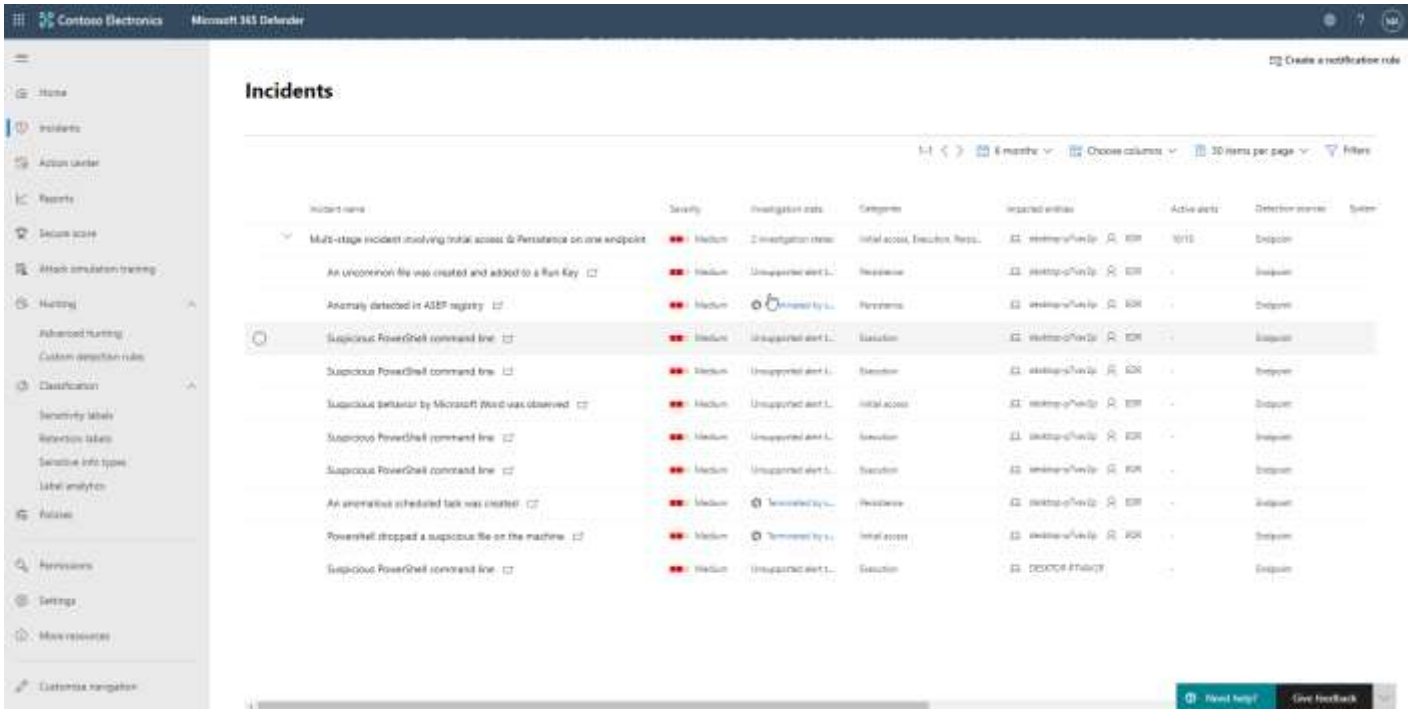
Circle

Selecting the circle will open a details window on the right side of the page with a preview of the line item with an option to open the full page of information.



Greater than symbol

If there are related records that can be displayed, selecting the greater than sign will display the records below the current record.



Link

The link will navigate you to the full page for the line item.

Manage incidents

Managing incidents is critical in ensuring that threats are contained and addressed. In Microsoft Defender XDR, you have access to managing incidents on devices, users, and mailboxes. You can manage incidents by selecting an incident from the Incidents queue.

You can edit the name of an incident, resolve it, set its classification and determination. You can also assign the incident to yourself, add incident tags and comments.

In cases where you would like to move alerts from one incident to another, during an investigation, you can also do so from the Alerts tab. Using the Alerts tab allows you to create a larger or smaller incident that includes all relevant alerts.

Edit incident name

Incidents are automatically assigned a name based on alert attributes such as the number of endpoints affected, users affected, detection sources, or categories. Naming based on alert attributes allows you to quickly understand the scope of the incident. You can modify the incident name to better align with your preferred naming convention.

Assign incidents

If an incident hasn't yet been assigned, you can select Assign to me to assign the incident to yourself. Doing so assumes ownership of not just the incident but also all the alerts associated with it.

Set status and classification

Incident status

You can categorize incidents (as Active, or Resolved) by changing their status as your investigation progresses. This ability to update status helps you organize and manage how your team can respond to incidents.

For example, your SOC analyst can review the urgent Active incidents for the day and decide to assign them to themselves for investigation.

Alternatively, your SOC analyst might set the incident as Resolved if the incident has been remediated. Resolving an incident will automatically close all open alerts that are part of the incident.

Classification and determination

You can choose not to set a classification or decide to specify whether an incident is true alert or false alert. Doing so helps the team see patterns and learn from them.

Add comments

You can add comments and view historical events about an incident to see previous changes made to it.

Whenever a change or comment is made to an alert, it's recorded in the Comments and history section.

Added comments instantly appear on the pane.

Add incident tags

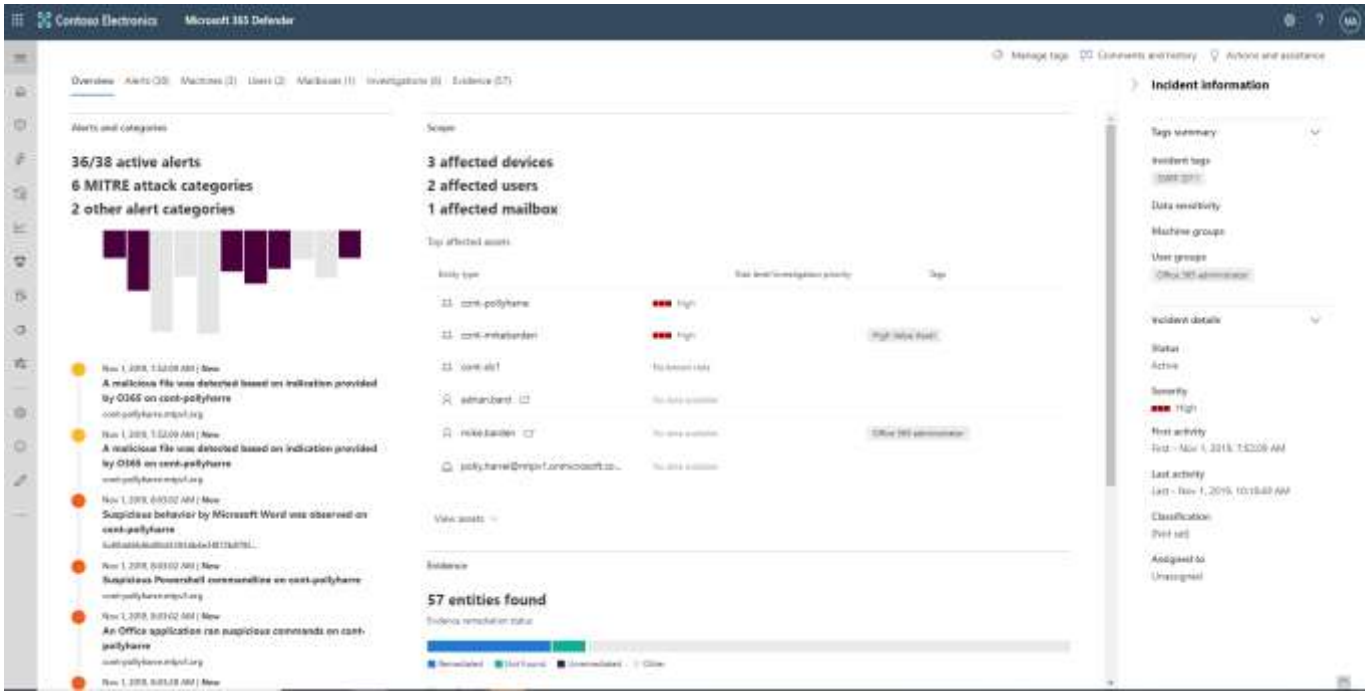
You can add custom tags to an incident, for example, to flag a group of incidents with common characteristics. You can later filter the incidents queue for all incidents that contain a specific tag.

Investigate incidents

The incident page provides the following information and navigation links.

Incident overview

The overview page gives you a snapshot glance into the top things to notice about the incident.



The attack categories give you a visual and numeric view of how advanced the attack has progressed against the kill chain. As with other Microsoft security products, Microsoft Defender XDR is aligned to the MITRE ATT&CK™ framework.

The scope section gives you a list of top impacted assets that are part of this incident. If there's specific information regarding this asset, such as risk level, investigation priority, and any tagging on the assets, it will also surface in this section.

The alerts timeline provides a sneak peek into the chronological order in which the alerts occurred and the reasons that these alerts linked to this incident.

And last - the evidence section provides a summary of how many different artifacts were included in the incident and their remediation status, so you can immediately identify if any action is needed on your end.

This overview can help the initial triage of the incident by providing insight into the top characteristics of the incident that you should be aware of.

Alerts

You can view all the alerts related to the incident and other information about them such as severity, entities that were involved in the alert, the source of the alerts (Microsoft Defender for Identity, Microsoft Defender for Endpoint, Microsoft Defender for Office 365), and the reason they were linked together.

By default, the alerts are ordered chronologically to allow you to first view how the attack played out over time. Clicking on each alert leads you to the relevant alert page, where you can conduct an in-depth investigation of that alert.

Devices

The devices tab lists all the devices where alerts related to the incident are seen.

Clicking on the name link of the machine where the attack was conducted navigates you to its Device page. On the Device page, you can see alerts that were triggered on it and related events provided to ease investigation.

Users

See users that are identified to be part of or related to a given incident.

Clicking the username navigates you to the user's Microsoft Defender for Cloud Apps page, where further investigation can be conducted.

Mailboxes

Investigate mailboxes that are identified to be part of or related to an incident.

Apps

Investigate Apps that are identified to be part of or related to an incident.

Investigations

Select Investigations to see all the automated investigations triggered by alerts in this incident. The investigations perform remediation actions or wait for analyst approval of actions.

Select an investigation to navigate to its Investigation details page to get full information on the investigation and remediation status. If any actions are pending for approval as part of the investigation, they appear in the Pending actions tab.

Evidence and Responses

Microsoft Defender XDR automatically investigates all the incidents' supported events and suspicious entities in the alerts, providing you with autoresponse and information about the important files, processes, services, emails, and more. This helps quickly detect and block potential threats in the incident.

Each of the analyzed entities are with a verdict (Malicious, Suspicious, Clean) and a remediation status. This helps you understand the remediation status of the entire incident and the next steps to further remediate.

Incident Graph

The graph visualizes associated cybersecurity threats information into an incident so you can see the patterns and correlations coming in from various data points. You can view such correlation through the incident graph.

The Graph tells the story of the cybersecurity attack. For example, it shows you the entry point, which indicator of compromise or activity was observed on which device, etc.

You can select the circles on the incident graph to view the details of the malicious files, associated file detections, how many instances there are worldwide, whether it’s observed in your organization, if so, how many instances.

Blast radius analysis (Preview)

Blast radius analysis extends the incident graph with an advanced, interactive view of both the current impact of a breach (post-breach) and the potential future impact (pre-breach) in one consolidated graph. It evaluates possible

propagation paths from a selected entity (for example, a compromised device or user) toward predefined critical targets, helping analysts quickly assess business impact and prioritize containment.

Note

Blast radius analysis extends and replaces Attack path analysis.

This capability utilizes Microsoft Sentinel graph and requires onboarding to the Microsoft Sentinel data lake (the underlying graph and data infrastructure). Without the Sentinel data lake, the blast radius experience doesn't appear.

Key value:

Unifies pre-breach exposure and post-breach spread in a single visualization.

Highlights top-rated attack paths (potential lateral movement routes) to critical assets.

Supports role-based scoping: paths and nodes rendered reflect the viewer's RBAC permissions.

Typical use cases by role:

Security analysts: Rapidly gauge scope and escalate or trigger disruption/containment along vulnerable paths.

SOC / IT engineers: Prioritize remediation and allocate resources based on potential reach to critical targets.

Incident responders: Visual incident map to guide targeted actions.

Security leadership (CISO): Communicate impact, set progress metrics, and track defensive posture over time.

Prerequisites:

Onboarded to Microsoft Sentinel data lake (Graph auto-provisioned; see "Onboard to Microsoft Sentinel data lake and graph").

Appropriate Defender XDR unified RBAC permissions (Exposure management read or higher).

How to use (from the incident graph):

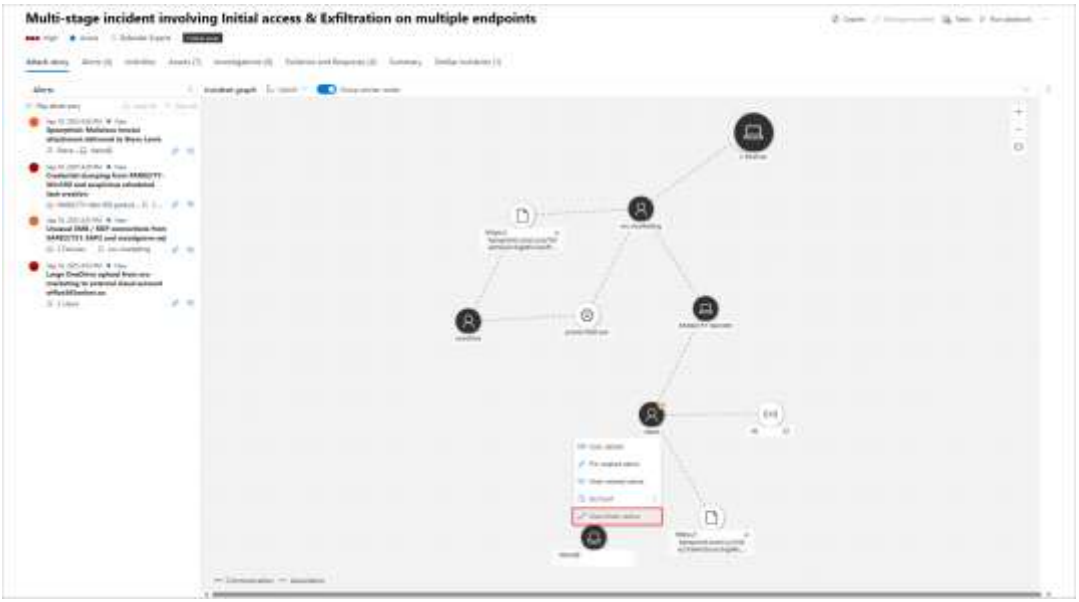
Select an entity node and choose "View blast radius."

Review the initial graph showing the top attack paths (you can open the full path list for expanded details).

Expand grouped targets to view discrete paths to individual critical assets.

Use context actions on nodes (isolate device, disable user, etc.) to interrupt likely lateral movement.

Select "Hide blast radius" to return to the default incident graph.



Limitations & modeling notes (summary):

Path depth is bounded (up to 7 hops overall; typical max 5 for cloud/on-prem, 3 for hybrid).

Graph renders possible—not guaranteed—paths derived from known attack vectors.

Data freshness lag may temporarily omit newly emerged relationships.

Visibility constrained by user's RBAC scope; out-of-scope nodes/edges aren't shown.

Island (disconnected) nodes can appear due to collection/calculation timing.

Manage and investigate alerts

You can manage alerts by selecting an alert in the Alerts queue or the Alerts tab of the Device page for an individual device. Selecting an alert in either of those places brings up the Alert management pane.



Alert management

You can view and set metadata on the Alert preview or Alert details page.

The metadata fields and actions include:

Severity

High (Red) - Alerts commonly seen associated with advanced persistent threats (APT). These alerts indicate a high risk because of the severity of damage they can inflict on devices. Examples include credential theft tools activities, ransomware activities not associated with any group, tampering with security sensors, or any malicious activities indicative of a human adversary.

Medium (Orange) - Alerts from endpoint detection and response post-breach behaviors that might be a part of an advanced persistent threat (APT). This includes observed behaviors typical of attack stages, anomalous registry change, execution of suspicious files, and so forth. Although some might be part of internal security testing, it requires investigation as it might also be a part of an advanced attack.

Low (Yellow) - Alerts on threats associated with prevalent malware. For example, hack-tools, nonmalware hack tools, such as running exploration commands, clearing logs, etc. often don't indicate an advanced threat targeting the organization. It could also come from an isolated security tool testing by a user in your organization.

Informational (Grey) - Alerts that might not be considered harmful to the network but can drive organizational security awareness on potential security issues.

Microsoft Defender Antivirus (Microsoft Defender AV) and Defender for Endpoint alert severities are different because they represent different scopes. The Microsoft Defender AV threat severity represents the absolute severity of the detected threat (malware) and is assigned based on the potential risk to the individual device if infected.

The Defender for Endpoint alert severity represents the severity of the detected behavior, the actual risk to the device, and most importantly, the potential risk to the organization.

So, for example:

The severity of a Defender for Endpoint alert about a Microsoft Defender AV detected threat that was prevented and didn't infect the device is categorized as "Informational" because there was no actual damage.

An alert about a commercial malware was detected while executing, but blocked and remediated by Microsoft Defender AV, is categorized as "Low" because it may have caused some damage to the individual device but poses no organizational threat.

An alert about malware detected while executing which can pose a threat not only to the individual device but to the organization, regardless if it was eventually blocked, may be ranked as "Medium" or "High".

Suspicious behavioral alerts, which weren't blocked or remediated will be ranked "Low", "Medium" or "High" following the same organizational threat considerations.

Categories

The alert categories align closely with the attack tactics and techniques in the MITRE ATT&CK Enterprise matrix.

Note

The alert categories also include items (like Unwanted Software) that are not part of the ATT&CK matrices.

The categories are:

Collection - Locating and collecting data for exfiltration

Command and control - Connecting to attacker-controlled network infrastructure to relay data or receive commands

Credential access - Obtaining valid credentials to extend control over devices and other resources in the network

Defense evasion - Avoiding security controls by, for example, turning off security apps, deleting implants, and running rootkits

Discovery - Gathering information about important devices and resources, such as administrator computers, domain controllers, and file servers

Execution - Launching attacker tools and malicious code, including RATs and backdoors

Exfiltration - Extracting data from the network to an external, attacker-controlled location

Exploit - Exploit code and possible exploitation activity

Initial access - Gaining initial entry to the target network, usually involving password-guessing, exploits, or phishing emails

Lateral movement - Moving between devices in the target network to reach critical resources or gain network persistence

Malware - Backdoors, trojans, and other types of malicious code

Persistence - Creating autostart extensibility points (ASEPs) to remain active and survive system restarts

Privilege escalation - Obtaining higher permission levels for code by running it in the context of a privileged process or account

Ransomware - Malware that encrypts files and extorts payment to restore access

Suspicious activity - Atypical activity that could be malware activity or part of an attack

Unwanted software - Low-reputation apps and apps that impact productivity and the user experience; detected as potentially unwanted applications (PUAs)

Link to another incident

You can create a new incident from the alert or link to an existing incident.

Assign alerts

If an alert isn't yet assigned, you can select Assign to me to assign the alert to yourself.

Suppress alerts

There might be scenarios where you need to suppress alerts from appearing in Microsoft Defender Security Center. Defender for Endpoint lets you create suppression rules for specific alerts that are known to be innocuous, such as known tools or processes in your organization.

Suppression rules can be created from an existing alert. They can be disabled and re-enabled if needed.

When a suppression rule is created, it takes effect from the point when the rule is created. The rule won't affect existing alerts already in the queue prior to the rule creation. The rule will only be applied to alerts that satisfy the conditions set after the rule is created.

There are two contexts for a suppression rule that you can choose from:

Suppress alert on this device

Suppress alert in my organization

The context of the rule lets you tailor what gets surfaced into the portal and ensure that only real security alerts are surfaced into the portal.

Change the status of an alert

You can categorize alerts as New, In Progress, or Resolved by changing their status as your investigation progresses. This helps you organize and manage how your team can respond to alerts.

For example, a team leader can review all New alerts, and decide to assign them to the In Progress queue for further analysis.

Alternatively, the team leader might assign the alert to the Resolved queue if they know the alert is benign, coming from an irrelevant device (such as one belonging to a security administrator), or is being dealt with through an earlier alert.

Alert classification

You can choose not to set a classification or specify whether an alert is a true alert or a false alert. It's important to provide the classification of true positive/false positive because it's used to monitor alert quality and make alerts more accurate. The "determination" field defines extra fidelity for a "true positive" classification.

Add comments and view the history of an alert

You can add comments and view historical events about an alert to see previous changes made to the alert. Whenever a change or comment is made to an alert, it's recorded in the Comments and history section. Added comments instantly appear on the pane.

Alert investigation

Investigate alerts that are affecting your network, understand what they mean, and how to resolve them.

Select an alert from the alerts queue to go to alert page. This view contains the alert title, the affected assets, the details side pane, and the alert story.

From the alert page, begin your investigation by selecting the affected assets or any of the entities under the alert story tree view. The details pane automatically populates with further information about what you selected.

Investigate using the alert story

The alert story details why the alert was triggered, related events that happened before and after, and other related entities.

Entities are clickable, and every entity that isn't an alert is expandable using the expand icon on the right side of that entity's card. The entity in focus will be indicated by a blue stripe to the left side of that entity's card, with the alert in the title being in focus at first.

Selecting an entity switches the context of the details pane to this entity, and will allow you to review further information, and manage that entity. Selecting ... to the right of the entity card reveals all actions available for that entity. These same actions appear in the details pane when that entity is in focus.

Take action from the details pane

Once you've selected an entity of interest, the details pane changes to display information about the selected entity type, historic information when it's available, and offer controls to take action on this entity directly from the alert page.

Once you're done investigating, go back to the alert you started with, mark the alert's status as Resolved and classify it as either False alert or True alert. Classifying alerts helps tune this capability to provide more true alerts and fewer false alerts.

If you classify it as a true alert, you can also select a determination.

If you're experiencing a false alert with a line-of-business application, create a suppression rule to avoid this type of alert in the future.

Manage automated investigations

Manage automated investigations

Your security operations team receives an alert whenever Microsoft Defender detects a malicious or suspicious artifact from an Endpoint. Security operations teams face challenges in addressing the multitude of alerts that arise from the seemingly never-ending flow of threats. Microsoft Defender for Endpoint includes automated investigation and remediation (AIR) capabilities that can help your security operations team address threats more efficiently and effectively.

The technology in automated investigation uses various inspection algorithms and is based on processes that are used by security analysts. AIR capabilities are designed to examine alerts and take immediate action to resolve breaches. AIR capabilities significantly reduce alert volume, allowing security operations to focus on more sophisticated threats and other high-value initiatives. The Action center keeps track of all the investigations that were initiated automatically, along with details, such as investigation status, detection source, and any pending or completed actions.

How the automated investigation starts

When an alert is triggered, a security playbook goes into effect. Depending on the security playbook, an automated investigation can start. For example, suppose a malicious file resides on a device. When that file is detected, an alert is triggered, and the automated investigation process begins. Microsoft Defender for Endpoint checks to see if the malicious file is present on any other devices in the organization. Details from the investigation, including verdicts (Malicious, Suspicious, and No threats found) are available during and after the automated investigation. To learn more about what happens after a verdict is reached, see Automated investigation results and remediation actions.

Details of an automated investigation

During and after an automated investigation, you can view details about the investigation. Select a triggering alert to view the investigation details. From there, you can go to the Investigation graph, Alerts, Devices, Evidence, Entities, and Log tabs.

Alerts - The alert(s) that started the investigation.

Devices - The device(s) where the threat was seen.

Evidence - The entities that were found to be malicious during an investigation.

Entities - Details about each analyzed entity, including a determination for each entity type (Malicious, Suspicious, or No threats found).

Log - The chronological, detailed view of all the investigation actions taken on the alert.

Pending actions - If there are any actions awaiting approval as a result of the investigation, the Pending actions tab is displayed. On the Pending actions tab, you can approve or reject each action.

How an automated investigation expands its scope

While an investigation is running, any other alerts generated from the device are added to an ongoing automated investigation until that investigation is completed. In addition, if the same threat is seen on other devices, those devices are added to the investigation.

If an incriminated entity is seen in another device, the automated investigation process expands its scope to include that device, and a general security playbook starts on that device. If ten or more devices are found during this expansion process from the same entity, then that expansion action requires approval and is visible on the Pending actions tab.

How threats are remediated

As alerts are triggered and an automated investigation runs, a verdict is generated for each piece of evidence investigated. Verdicts can be Malicious, Suspicious, or No threats found.

As verdicts are reached, automated investigations can result in one or more remediation actions. Examples of remediation actions include sending a file to quarantine, stopping a service, removing a scheduled task, and more. (See Remediation actions.)

Depending on the level of automation set for your organization, and other security settings, remediation actions can occur automatically or only upon approval by your security operations team. Other security settings that can affect automatic remediation include protection from potentially unwanted applications (PUA).

All remediation actions, whether pending or completed, can be viewed in the Action Center https://security.microsoft.com. If necessary, your security operations team can undo a remediation action.

Automation levels in automated investigation and remediation capabilities

Automated investigation and remediation (AIR) capabilities in Microsoft Defender for Endpoint can be configured to one of several levels of automation. Your automation level affects whether remediation actions following AIR investigations are taken automatically or only upon approval.

Full automation (recommended) means remediation actions are taken automatically on artifacts determined to be malicious.

Semi-automation means some remediation actions are taken automatically, but other remediation actions await approval before being taken. (See the table in Levels of automation.)

All remediation actions, whether pending or completed, are tracked in the Action Center

Levels of automation

Full - remediate threats automatically (also referred to as full automation)

With full automation, remediation actions are performed automatically. All remediation actions that are taken can be viewed in the Action Center on the History tab. If necessary, a remediation action can be undone.

Semi - require approval for any remediation (also referred to as semi-automation)

With this level of semi-automation, approval is required for any remediation action. Such pending actions can be viewed and approved in the Action Center, on the Pending tab.

Semi - require approval for core folders remediation (also a type of semi-automation)

With this level of semi-automation, approval is required for any remediation actions needed on files or executables that are in core folders. Core folders include operating system directories, such as the Windows (\windows*).

Remediation actions can be taken automatically on files or executables that are in other (non-core) folders.

Pending actions for files or executables in core folders can be viewed and approved in the Action Center, on the Pending tab.

Actions that were taken on files or executables in other folders can be viewed in the Action Center, on the History tab.

Semi - require approval for non-temp folders remediation (also a type of semi-automation)

With this level of semi-automation, approval is required for any remediation actions needed on files or executables that aren't in temporary folders.

Temporary folders can include the following examples:

\users*\appdata\local\temp*

\documents and settings*\local settings\temp*

\documents and settings*\local settings\temporary*

\windows\temp*

\users*\downloads*

\program files\

\program files (x86)*

\documents and settings*\users*

Remediation actions can be taken automatically on files or executables that are in temporary folders.

Pending actions for files or executables that aren't in temporary folders can be viewed and approved in the Action Center, on the Pending tab.

Actions that were taken on files or executables in temporary folders can be viewed and approved in the Action Center on the History tab.

No automated response (also referred to as no automation)

With no automation, the automated investigation doesn't run on your organization's devices. As a result, no remediation actions are taken or pending as a result of an automated investigation. However, other threat protection features, such as protection from potentially unwanted applications, can be in effect, depending on how your antivirus and next-generation protection features are configured.

Using the no automation option isn't recommended because it reduces the security posture of your organization's devices. Consider setting up your automation level to full automation (or at least semi-automation).

Important points about automation levels

Full automation has proven to be reliable, efficient, and safe, and is recommended for all customers. Full automation frees up your critical security resources so they can focus more on your strategic initiatives. If your security team has defined device groups with a level of automation, those settings aren't changed by the new default settings that are rolling out.

Use the action center

Action center

The unified Action center of the Microsoft Defender portal lists pending and completed remediation actions for your devices, email & collaboration content, and identities in one location.

The unified Action center brings together remediation actions across Defender for Endpoint and Defender for Office 365. It defines a common language for all remediation actions and provides a unified investigation experience. Your security operations team has a "single pane of glass" experience to view and manage remediation actions.

The Action Center consists of pending and historical items:

Pending displays a list of ongoing investigations that require attention. Recommended actions are presented that your security operations team can approve or reject. The Pending tab appears only if there are pending actions to be approved (or rejected).

History as an audit log for all of the following items:

Remediation actions that were taken as a result of an automated investigation

Remediation actions that were approved by your security operations team (some actions, such as sending a file to quarantine, can be undone)

Commands that were run and remediation actions that were applied in Live Response sessions (some actions can be undone)

Remediation actions that were applied by Microsoft Defender Antivirus (some actions can be undone)

Select Automated Investigations, then Action center.

When an automated investigation runs, a verdict is generated for each piece of evidence investigated. Verdicts can be Malicious, Suspicious, or No threats found depending on:

Type of threat

Resulting verdict

How your organization's device groups are configured

Remediation actions can occur automatically or only upon approval by your organization’s security operations team.

Review pending actions

To approve or reject a pending action:

Select any item on the Pending tab.

Select an investigation from any of the categories to open a panel where you can approve or reject remediation actions.

Other details, such as file or service details, investigation details, and alert details are displayed. From the panel, you can select the Open investigation page link to see the investigation details. You can also select multiple investigations to approve or reject actions on multiple investigations.

Review completed actions

To review completed actions:

Select the History tab. (If need be, expand the time period to display more data.)

Select an item to view more details about that remediation action.

Undo completed actions

You’ve determined that a device or a file isn't a threat. You can undo remediation actions that were taken, whether those actions were taken automatically or manually. You can undo any of the following actions:

Source

Automated investigation

Microsoft Defender Antivirus

Manual response actions

Supported Actions

Isolate device

Restrict code execution

Quarantine a file

Remove a registry key

Stop a service

Disable a driver

Remove a scheduled task

Remove a file from quarantine across multiple devices

To remove a file from quarantine across multiple devices:

On the History tab, select a file that has the Action type Quarantine file.

In the pane on the right side of the screen, select Apply to X more instances of this file, and then select Undo.

Viewing action source details

The Action center includes an Action source column that tells you where each action came from. The following table describes possible Action source values:

Action source value	Description
Manual device action	A manual action taken on a device. Examples include device isolation or file quarantine.
Manual email action	A manual action taken on email. An example includes soft-deleting email messages or remediating an email message.
Automated device action	An automated action taken on an entity, such as a file or process. Examples of automated actions include sending a file to quarantine, stopping a process, and removing a registry key.
Automated email action	An automated action taken on email content, such as an email message, attachment, or URL. Examples of automated actions include soft-deleting email messages, blocking URLs, and turning off external mail forwarding.
Advanced hunting action	Actions taken on devices or email with advanced hunting.
Explorer action	Actions taken on email content with Explorer.
Manual live response action	Actions taken on a device with live response. Examples include deleting a file, stopping a process, and removing a scheduled task.
Live response action	Actions taken on a device with Microsoft Defender for Endpoint APIs. Examples of actions include isolating a device, running an antivirus scan, and getting information about a file.

Submissions

In Microsoft 365 organizations with Exchange Online mailboxes, admins can use the Submissions portal in the Microsoft Defender portal to submit email messages, URLs, and attachments to Microsoft for scanning.

When you submit an email message for analysis, you'll get:

Email authentication check: Details on whether email authentication passed or failed when it was delivered.

Policy hits: Information about any policies that may have allowed or blocked the incoming email into your tenant, overriding our service filter verdicts.

Payload reputation/detonation: Up-to-date examination of any URLs and attachments in the message.

Grader analysis: Review done by human graders in order to confirm whether or not messages are malicious.

Important

Payload reputation/detonation and grader analysis are not done in all tenants. Information is blocked from going outside the organization when data is not supposed to leave the tenant boundary for compliance purposes.

What do you need to know before you begin?

To submit messages and files to Microsoft, you need to have one of following roles:

Security Administrator or Security Reader in the Microsoft Defender portal.

Admins can submit messages as old as 30 days if it's still available in the mailbox and not purged by the user or another admin.

Admin submissions are throttled at the following rates:

Maximum submissions in any 15-minutes period: 150 submissions

Same submissions in a 24 hour period: Three submissions

Same submissions in a 15-minute period: One submission

Report suspicious content to Microsoft

On the Submissions page, verify that the Emails, Email attachments, or URLs tab is selected based on the type of content you want to report. And then select the Submit to Microsoft for analysis icon. Submit to Microsoft for analysis.

Use the Submit to Microsoft for analysis flyout that appears to submit the respective type of content (email, URL, or email attachment).

Note

File and URL submissions are not available in the clouds that do not allow for data to leave the environment. The ability to select File or URL will be greyed out.

Notify users from within the portal

On the Submissions page, select User reported messages tab, and then select the message you want to mark and notify.

Select the Mark as and notify drop-down, and then select No threats found > Phishing or Junk.

The reported message will be marked as a false positive or a false negative. An email notification is sent automatically from within the portal to the user who reported the message.

Submit a questionable email to Microsoft

In the Select the submission type box, verify that Email is selected in the dropdown list.

In the Add the network message ID or upload the email file section, use one of the following options:

Add the email network message ID: The ID is a GUID value that's available in the X-MS-Exchange-Organization-Network-Message-Id header in the message or in the X-MS-Office365-Filtering-Correlation-Id header in quarantined messages.

Upload the email file (.msg or .eml): Select Browse files. In the dialog that opens, find and select the .eml or .msg file, and then select Open.

In the Choose a recipient who had an issue box, specify the recipient that you would like to run a policy check against. The policy check will determine if the email bypassed scanning due to user or organization policies.

In the Select a reason for submitting to Microsoft section, select one of the following options:

Shouldn't have been blocked (False positive)

Should have been blocked (False negative): In the, "The email should have been categorized as" section that appears, select one of the following values (if you're not sure, use your best judgment): Phish, Malware, or Spam

When you're finished, select Submit.

Send a suspect URL to Microsoft

In the Select the submission type box, select URL from the dropdown list.

In the URL box that appears, enter the full URL. For example, https://www.fabrikam.com/marketing.html.

In the Select a reason for submitting to Microsoft section, select one of the following options:

Shouldn't have been blocked (False positive)

Should have been blocked (False negative): In the, "This URL should have been categorized as" section that appears, select one of the following values (if you're not sure, use your best judgment): Phish, Malware

When you're finished, select Submit.

Submit a suspected email attachment to Microsoft

In the Select the submission type box, select Email attachment from the dropdown list.

In the File section that appears, select Browse files. In the dialog that opens, find and select the file, and then select Open.

In the Select a reason for submitting to Microsoft section, select one of the following options:

Shouldn't have been blocked (False positive)

Should have been blocked (False negative): In the, "This file should have been categorized as" section that appears, select one of the following values (if you're not sure, use your best judgment): Phish, Malware

When you're finished, select Submit.

Note

If malware filtering has replaced the message attachments with the Malware Alert Text.txt file, you need to submit the original message from quarantine that contains the original attachments. For more information on quarantine and how to release messages with malware false positives, see Manage quarantined messages and files as an admin.

View admin submissions to Microsoft

On the Submissions page, verify that the Emails, URL, or Email attachment tab is selected.

You can sort the entries by clicking on an available column header. Select Customize columns to show a maximum of seven columns. The default values are marked with an asterisk (*):

Submission name*

Sender*

Recipient

Date submitted*

Reason for submitting*

Status*

Result*

Filter verdict

Delivery/Block reason

Submission ID

Network Message ID/Object ID

Direction

Sender IP

Bulk compliant level (BCL)

Destination

Policy action

Submitted by

Phish simulation

Tags*

Allow

When you're finished, select Apply.

Admin submission result details

Messages that are submitted in admin submissions are reviewed and results shown in the submissions detail flyout:

If there was a failure in the sender's email authentication at the time of delivery.

Information about any policy hits that could have affected or overridden the verdict of a message.

Current detonation results to see if the URLs or files contained in the message are malicious or not.

Feedback from graders.

If an override was found, the result should be available in several minutes. If there wasn't a problem in email authentication or delivery wasn't affected by an override, then the feedback from graders could take up to a day.

View user submissions to Microsoft

If you've deployed the Report Message add-in, the Report Phishing add-in, or people use the built-in reporting in Outlook on the web, you can see what users are reporting on the User reported message tab.

On the Submissions page, select the User reported messages tab.

You can sort the entries by clicking on an available column header. Select Customize columns to show the options. The default values are marked with an asterisk (*):

Email subject*

Reported by*

Date reported*

Sender*

Reported reason*

Result*

Message reported ID

Network Message ID

Sender IP

Reported from

Phish simulation

Converted to admin submission

Tags*

Marked as*

Marked by

Date marked

When you're finished, select Apply.

Note

If organizations are configured to send user reported messages to the custom mailbox only, reported messages will appear in User reported messages but their results will always be empty (as they would not have been rescanned).

Undo user submissions

Once a user submits a suspicious email to the custom mailbox, the user and admin don't have an option to undo the submission. If the user would like to recover the email, it will be available for recovery in the Deleted Items or Junk Email folders.

Converting user reported messages from the custom mailbox into an admin submission

If you've configured the custom mailbox to intercept user-reported messages without sending the messages to Microsoft, you can find and send specific messages to Microsoft for analysis.

On the User reported messages tab, select a message in the list, select Submit to Microsoft for analysis, and then select one of the following values from the dropdown list:

Report clean

Report phishing

Report malware

Report spam

Trigger investigation

Explore advanced hunting

Advanced hunting is a query-based threat-hunting tool that lets you explore up to 30 days of raw data. You can proactively inspect events in your network to locate threat indicators and entities. The flexible access to data enables unconstrained hunting for both known and potential threats.

You can use the same threat-hunting queries to build custom detection rules. These rules run automatically to check for and then respond to suspected breach activity, misconfigured machines, and other findings. The advanced hunting capability supports queries that check a broader data set from:

Microsoft Defender for Endpoint

Microsoft Defender for Office 365

Microsoft Defender for Cloud Apps

Microsoft Defender for Identity

To use advanced hunting, turn on Microsoft Defender XDR.

Data freshness and update frequency

Advanced hunting data can be categorized into two distinct types, each consolidated differently.

Event or activity data—populates tables about alerts, security events, system events, and routine assessments. Advanced hunting receives this data almost immediately after the sensors that collect them successfully transmit them to the corresponding cloud services. For example, you can query event data from healthy sensors on workstations or domain controllers almost immediately after they're available on Microsoft Defender for Endpoint and Microsoft Defender for Identity.

Entity data—populates tables with information about users and devices. This data comes from both relatively static data sources and dynamic sources, such as Active Directory entries and event logs. To provide fresh data, tables are updated with any new information every 15 minutes, adding rows that might not be fully populated. Every 24 hours, data is consolidated to insert a record that contains the latest, most comprehensive data set about each entity.

Time zone

Time information in advanced hunting is in the UTC zone.

Data schema

The advanced hunting schema is made up of multiple tables that provide either event information or information about devices, alerts, identities, and other entity types. To effectively build queries that span multiple tables, you need to understand the tables and the columns in the advanced hunting schema.

Get schema information

While constructing queries, use the built-in schema reference to quickly get the following information about each table in the schema:

Table description—type of data contained in the table and the source of that data.

Columns—all the columns in the table.

Action types—possible values in the ActionType column representing the event types supported by the table. This information is provided only for tables that contain event information.

Sample query—example queries that feature how the table can be utilized.

Access the schema reference

To quickly access the schema reference, select the View reference action next to the table name in the schema representation. You can also select Schema reference to search for a table.

Learn the schema tables

The following reference lists all the tables in the schema. Each table name links to a page describing the column names for that table. Table and column names are also listed in the security center as part of the schema representation on the advanced hunting screen.

Table name	Description
AlertEvidence	Files, IP addresses, URLs, users, or devices associated with alerts
AlertInfo	Alerts from Microsoft Defender for Endpoint, Microsoft Defender for Office 365, Microsoft Cloud App Security, and Microsoft Defender for Identity, including severity information and threat categorization
CloudAppEvents	Events involving accounts and objects in Office 365 and other cloud apps and services
DeviceEvents	Multiple event types, including events triggered by security controls such as Windows Defender Antivirus and exploit protection
DeviceFileCertificateInfo	Certificate information of signed files obtained from certificate verification events on endpoints

Table name	Description
DeviceFileEvents	File creation, modification, and other file system events
DeviceImageLoadEvents	DLL loading events
DeviceInfo	Machine information, including OS information
DeviceLogonEvents	Sign-ins and other authentication events on devices
DeviceNetworkEvents	Network connection and related events
DeviceNetworkInfo	Network properties of devices, including physical adapters, IP and MAC addresses, as well as connected networks and domains
DeviceProcessEvents	Process creation and related events
DeviceRegistryEvents	Creation and modification of registry entries
DeviceTvmSecureConfigurationAssessment	Threat & Vulnerability Management assessment events, indicating the status of various security configurations on devices
DeviceTvmSecureConfigurationAssessmentKB	Knowledge base of various security configurations used by Threat & Vulnerability Management to assess devices; includes mappings to various standards and benchmarks
DeviceTvmSoftwareInventory	Inventory of software installed on devices, including their version information and end-of-support status
DeviceTvmSoftwareVulnerabilities	Software vulnerabilities found on devices and the list of available security updates that address each vulnerability
DeviceTvmSoftwareVulnerabilitiesKB	Knowledge base of publicly disclosed vulnerabilities, including whether exploit code is publicly available
EmailAttachmentInfo	Information about files attached to emails
EmailEvents	Microsoft 365 email events, including email delivery and blocking events
EmailPostDeliveryEvents	Security events that occur post-delivery, after Microsoft 365 delivered the emails to the recipient mailbox
EmailUrlInfo	Information about URLs on emails
IdentityDirectoryEvents	Events involving an on-premises domain controller running Active Directory (AD). This table covers a range of identity-related events and system events on the domain controller.
IdentityInfo	Account information from various sources, including Microsoft Entra ID
IdentityLogonEvents	Authentication events on Active Directory and Microsoft online services
IdentityQueryEvents	Queries for Active Directory objects, such as users, groups, devices, and domains

Custom detections

With custom detections, you can proactively monitor for and respond to various events and system states, including suspected breach activity and misconfigured endpoints. This is made possible by customizable detection rules that automatically trigger alerts and response actions.

Custom detections work with advanced hunting, which provides a powerful, flexible query language that covers a broad set of event and system information from your network. You can set them to run at regular intervals, generating alerts and taking response actions whenever there are matches.

Custom detections provide:

Alerts for rule-based detections built from advanced hunting queries

Automatic response actions that apply to files and devices

Create detection rules

To create detection rules:

1. Prepare the query.

In Microsoft Defender Security Center, go to Advanced hunting and select an existing query or create a new query. When using a new query, run the query to identify errors and understand possible results.

Important

To prevent the service from returning too many alerts, each rule is limited to generating only 100 alerts whenever it runs. Before creating a rule, tweak your query to avoid alerting for normal, day-to-day activity.

To use a query for a custom detection rule, the query must return the following columns:

Timestamp

DeviceId

ReportId

Simple queries, such as those that don't use the project or summarize operator to customize or aggregate results, typically return these common columns.

There are various ways to ensure more complex queries return these columns. For example, if you prefer to aggregate and count by DeviceId, you can still return Timestamp and ReportId by getting them from the most recent event involving each device.

The sample query below counts the number of unique devices (DeviceId) with antivirus detections and uses this to find only those devices with more than five detections. To return the latest Timestamp and the corresponding ReportId, it uses the summarize operator with the arg_max function.

Kusto

```
DeviceEvents
| where Timestamp > ago(7d)
| where ActionType == "AntivirusDetection"
| summarize (Timestamp, ReportId)=arg_max(Timestamp, ReportId), count() by DeviceId
| where count_ > 5
```

2. Create a new rule and provide alert details.

With the query in the query editor, select Create detection rule and specify the following alert details:

Detection name—name of the detection rule

Frequency—interval for running the query and taking action. See more guidance below

Alert title—title displayed with alerts triggered by the rule

Severity—potential risk of the component or activity identified by the rule.

Category—type of threat component or activity, if any.

MITRE ATT&CK techniques—one or more attack techniques identified by the rule as documented in the MITRE ATT&CK framework. This section isn't available with certain alert categories, such as malware, ransomware, suspicious activity, and unwanted software

Description—more information about the component or activity identified by the rule

Recommended actions—additional actions that responders might take in response to an alert

3. Rule frequency

When saved, a new custom detection rule immediately runs and checks for matches from the past 30 days of data. The rule then runs again at fixed intervals and lookback durations based on the frequency you choose:

Every 24 hours—runs every 24 hours, checking data from the past 30 days

Every 12 hours—runs every 12 hours, checking data from the past 48 hours

Every 3 hours—runs every 3 hours, checking data from the past 12 hours

Every hour—runs hourly, checking data from the past 4 hours

Continuous (NRT)—runs continuously, checking data from events as they're collected and processed in near real-time (NRT)

Select the frequency that matches how closely you want to monitor detections, and consider your organization's capacity to respond to the alerts.

Note

Setting a custom detection to run in Continuous (NRT) frequency allows you to increase your organization's ability to identify threats faster.

4. Choose the impacted entities.

Identify the columns in your query results where you expect to find the main affected or impacted entity. For example, a query might return both device and user IDs. Identifying which of these columns represents the main impacted entity helps the service aggregate relevant alerts, correlate incidents, and target response actions.

You can select only one column for each entity type. Columns not returned by your query can't be selected.

5. Specify actions.

Your custom detection rule can automatically take actions on files or devices returned by the query.

Actions on devices

These actions are applied to devices in the DeviceId column of the query results:

Isolate device—applies full network isolation, preventing the device from connecting to any application or service, except for the Defender for Endpoint service.

Collect investigation package—collects device information in a ZIP file.

Run antivirus scan—performs a full Microsoft Defender Antivirus scan on the device

Initiate investigation—starts an automated investigation on the device

Actions on files

These actions are applied to files in the SHA1 or the InitiatingProcessSHA1 column of the query results:

Allow/Block—automatically adds the file to your custom indicator list so that it's always allowed to run or blocked from running. You can set the scope of this action so that it's taken only on selected device groups. This scope is independent of the scope of the rule.

Quarantine file—deletes the file from its current location and places a copy in quarantine

6. Set the rule scope.

Set the scope to specify which devices are covered by the rule:

All devices

Specific device groups

Only data from devices in scope are queried. Also, actions are taken only on those devices.

7. Review and turn on the rule.

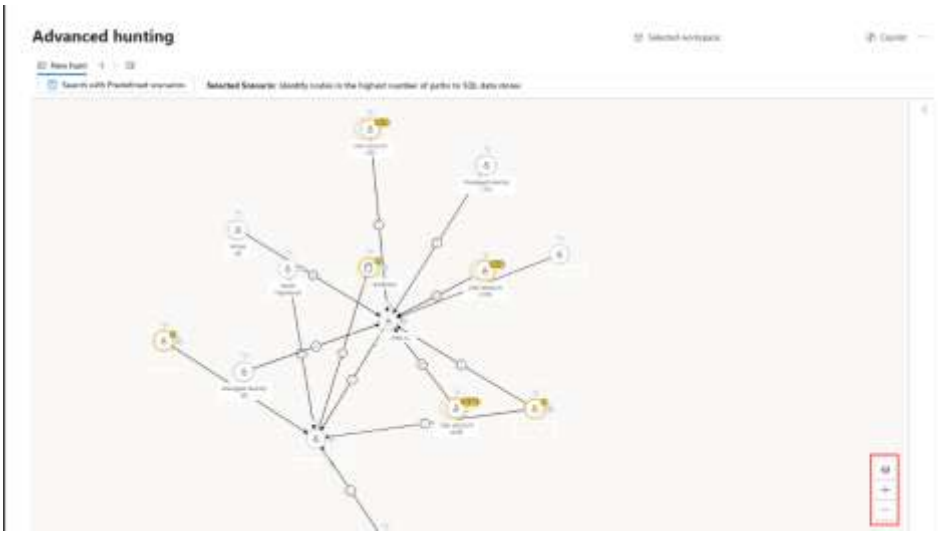
After reviewing the rule, select Create to save it. The custom detection rule immediately runs. It runs again based on configured frequency to check for matches, generate alerts, and take response actions.

Visualize threat paths with the Hunting graph (Preview)

Important

The Hunting graph is in Preview. Capabilities may change before general availability.

The Hunting graph is the Microsoft Sentinel graph integration with Microsoft Defender XDR. It extends advanced hunting by rendering predefined threat scenarios as interactive, graph-based visualizations. Instead of manually stitching relationships through KQL joins, you can visually traverse entities (nodes) and their relationships (edges) to quickly spot attack paths, choke points, or over-privileged identities.



Why use the Hunting graph?

Use it when you need to:

Trace potential lateral-movement paths between two entities.

Assess exposure to sensitive assets (Key Vaults, storage accounts, SQL data stores, Kubernetes clusters).

Inventory identities with access to high-value repositories (for example, Azure DevOps).

Prioritize mitigation by finding nodes that appear in many critical paths.

It complements tabular KQL queries: start visually to scope the investigation, then pivot to advanced hunting queries or custom detections for automation.

Prerequisites and access

You need:

Appropriate Microsoft Entra ID role for advanced hunting.

Access to the Microsoft Sentinel data lake (for cross-workspace graph data).

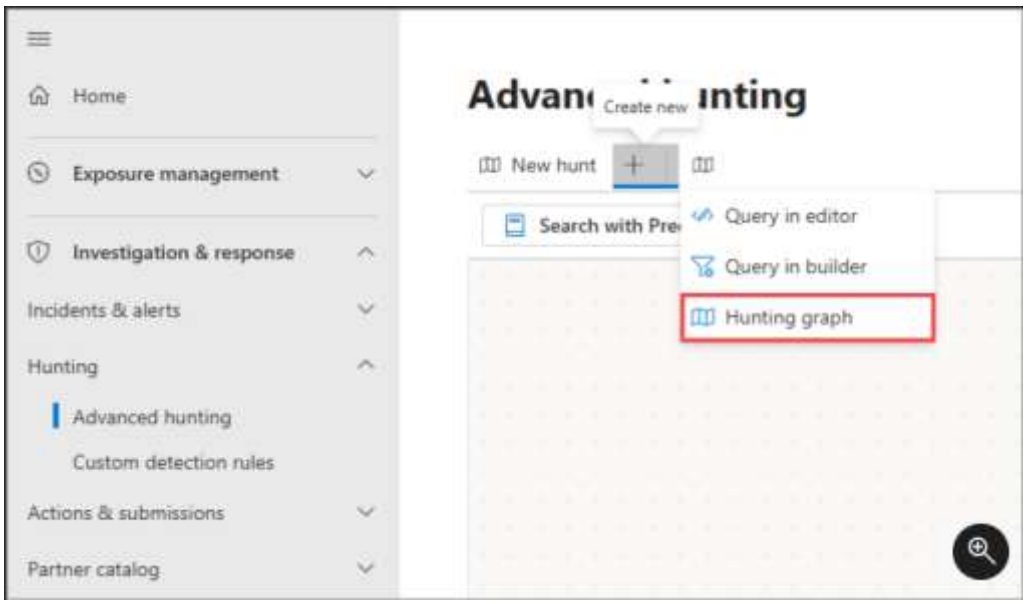
At least read-only access in Microsoft Security Exposure Management.

How to launch it

In the Microsoft Defender portal: Investigation & response > Hunting > Advanced hunting.

In the Advanced hunting page toolbar, select the hunting graph icon, or choose Create new > Hunting graph.

A new tab labeled “New hunt” opens.



Graph basics

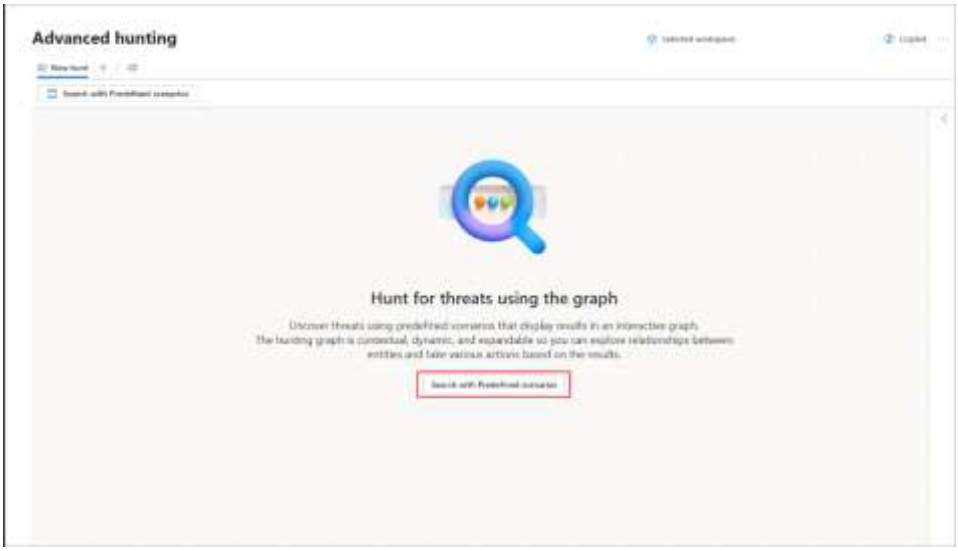
Nodes represent entities (users, devices, storage accounts, clusters, repositories, etc.).

Edges represent relationships (permissions, authentication capability, membership, traffic routing, containment).

Controls in the lower-right let you zoom and manage Layers (helpful for decluttering dense graphs).

Using predefined scenarios

Choose “Search with predefined scenarios” to load a guided panel.



Scenarios bundle queries + relationship logic. Common examples:

Scenario	What it helps you answer	Input required
Paths between two entities	Is there a traversable path from A to B?	Start entity, End entity
Users with access to sensitive data	Which users can reach a sensitive storage asset?	Target storage account
Data exfiltration by a device	What storage accounts can a given device access?	Source device
Paths to a highly critical Kubernetes cluster	Which actors can reach a critical cluster?	Target Kubernetes cluster
Identities with access to Azure DevOps repositories	Who can read/write a specific repo?	Target ADO repository
Nodes in highest number of paths to SQL data stores	Which nodes are high-leverage for reaching SQL assets?	None
Critical users with access to sensitive storage	Which privileged identities can touch sensitive data?	None
Entities that have access to a key vault	Who (directly or indirectly) can reach a Key Vault?	Target key vault

For scenarios with inputs, type or search the entity name/ID. Direction matters for “Paths between two entities” (start → end).

Refining with filters

Use panel filters to narrow focus:

Shortest paths only (quickly identify minimal traversal).

Source / Target node constraints (Is critical, Is vulnerable, Has sensitive data, Has risk score, Exposed to internet).

Edge type filters (for example: has permissions to, can authenticate as, member of, routes traffic to, has role on, can impersonate as).

Remove individual filters or clear all to broaden exploration.

Rendering and exploring

After selecting scenario + filters:

Select Run to generate the graph.

Select nodes to view enriched context (roles, sensitivity, exposure).

Expand or focus on subregions if paths are dense.

Identify repeated intermediate nodes (potential choke points or escalation catalysts).

Workflow integration

Goal	Suggested approach
Hypothesize lateral movement	Use "Paths between two entities" then build a KQL query to validate event evidence.
Privilege review	Run "Critical users with access..." and export involved identities to an access review process.
Data exfiltration triage	Start with "Data exfiltration by a device" to scope possible targets, then craft a custom detection for unusual transfer volumes.
Attack surface reduction	Use "Nodes in highest number of paths..." to find over-centralized assets and apply segmentation or least privilege.

Investigate Microsoft Entra sign-in logs

To perform a sign-in investigation including conditional access policies evaluated, you can query the following tables with KQL:

Location	Table
Microsoft Defender XDR Threat Hunting	AADSignInEventsBeta
Microsoft Entra ID Log Analytics	SigninLogs

The Microsoft Entra monitoring Sign-in Logs provide access to the same information available in the SigninLogs table. To access the Sign-in Logs blade, select Microsoft Entra ID in the Azure portal, then Sign-in Logs in the Monitoring Group. The query output will provide default columns including the Date, User, Application, Status, and Conditional Access (policy applied).

Understand Microsoft Secure Score

The Secure Score is a holistic view of the Microsoft Secure Score (365), which is a measurement of an organization's security posture, with a higher number indicating more recommended actions taken, and the Cloud Secure score (Risk based), that is a representation of your organizations cloud security posture. They're part of the Exposure Management tools in the Microsoft Defender portal.

Following the Secure Score recommendations can protect your organization from threats. From a centralized dashboard in the Microsoft Defender portal, organizations can monitor and work on the security of their Microsoft 365 identities, apps, and devices.

Organizations gain access to robust visualizations of metrics and trends, integration with other Microsoft products, score comparison with similar organizations, and much more. The score can also reflect when third-party solutions have addressed recommended actions.

Products included in Secure Score

Currently there are recommendations for the following products:

Microsoft Defender for Office

Exchange Online

Microsoft Entra ID

Microsoft Defender for Endpoint

Microsoft Defender for Identity

Microsoft Defender for Cloud Apps

Microsoft Purview Information Protection

Defender for Cloud Apps

Microsoft Teams

App governance

Citrix ShareFile

Docusign

GitHub

Okta

Salesforce

ServiceNow

SharePoint Online

Zoom

You can also mark the improvement actions as covered by a third party or alternate mitigation.

Take action to improve your score

The Recommended actions tab lists the security recommendations that address possible attack surfaces. It also includes their status (to address, planned, risk accepted, resolved through third party, resolved through alternate mitigation, and completed). You can search, filter, and group all the improvement actions.

Analyze threat analytics with the Security Copilot Threat Intelligence Briefing Agent

Threat intelligence analysts often need to gather data from multiple feeds and tools before they can create a useful briefing. The (embedded) Security Copilot Threat Intelligence Briefing Agent in Microsoft Defender helps reduce that effort by generating a briefing in minutes based on recent threat actor activity and your organization's vulnerability context.

The briefing is designed to support CISOs, security managers, and analysts with prioritized, actionable intelligence. As the agent builds the briefing, it dynamically decides what to analyze next based on previous results.

Watch this video to see the Threat Intelligence Briefing Agent in action.

Find the Threat Intelligence Briefing Agent in Threat analytics

In Microsoft Defender, open Threat intelligence > Threat analytics. The Threat Intelligence Briefing Agent appears as a banner at the top of the Threat Analytics dashboard page.

Prerequisites for using the agent

Before you use the agent, make sure these requirements are in place:

Microsoft Security Copilot is available in your environment.

Required Security Copilot plugins:

Microsoft Threat Intelligence

Microsoft Threat Intelligence agents

Optional plugin:

Microsoft Defender External Attack Surface Management

The connected user account or agent identity has appropriate permissions, including:

Access to Defender Vulnerability Management data

Security Reader access to Threat analytics and results

Security Admin access for onboarding and configuration

Run and review briefings

After prerequisites are complete, use the agent banner to run an up-to-date briefing or open the full briefing panel.

The full briefing panel summarizes threats, vulnerable exposures, and potential business impact. You can copy the briefing or download it as markdown for sharing.

Manage agent settings

Select Manage agent to review or update agent settings, such as schedule behavior and briefing preferences.

You can also open settings from System > Settings > Microsoft Defender XDR > Threat Intelligence Briefing Agent.

Assess output and provide feedback

Generated briefings are saved in Security Copilot under Activity, where you can inspect run status and review previous reports.

To evaluate agent reasoning and workflow transparency, open a generated report and select View activity.

Use thumbs up or thumbs down in the briefing panel to provide feedback and help improve future agent output.

Analyze reports

The Reports blade in the Microsoft Defender portal provides access to all the available reports for Microsoft Defender for Endpoint and Microsoft Defender for Office 365.

General

Name	Description
Security report	View information about security trends and track the protection status of your identities, data, devices, apps, and infrastructure.

Endpoints

Name	Description
Threat protection	See details about the security detections and alerts in your organization.
Device health and compliance	Monitor the health state, antivirus status, operating system platforms, and Windows 10 versions for devices in your organization.
Vulnerable devices	View information about the vulnerable devices in your organization, including their exposure to vulnerabilities by severity level, exploitability, age, and more.
Web protection	Get information about the web activity and web threats detected within your organization.
Firewall	View connections blocked by your firewall including related devices, why they were blocked, and which ports were used
Device control	This report shows your organization's media usage data.
Attack surface reduction rules	View information about detections, misconfiguration, and suggested exclusions in your environment.

Email & Collaboration

Name	Description
Email & collaboration reports	Review Microsoft recommended actions to help improve email and collaboration security.
Manage schedules	Manage the schedule for the reports security teams use to mitigate and address threats to your organization.
Reports for download	Download one or more of your reports.
Exchange mail flow reports	Deep link to Exchange mail flow report in the Exchange admin center.

Configure the Microsoft Defender portal

The Settings page lets you configure related Microsoft Defender products. The specific settings for the Defender products will be discussed in the related learning content. The primary setting for Microsoft Defender XDR is the notifications email configuration.

Types of Microsoft Defender portal email notifications

When you set up email notifications, you can choose from two types, as described in the following table:

Notification type	Description
Incidents	When new Incidents are created
Threat Analytics	When new Threat Analytic reports are created

Manage Incident email notifications

To view, add or edit Incident email notification settings for your organization, follow these steps:

In the navigation pane, select Settings, and then select Microsoft Defender XDR. Then, select Email notifications.

Next, select Incidents

To add a new notification:

Select Add incident email notification.

Enter a name and description, then next.

Select device and alert criteria, then next.

Enter the recipients email address, then next.

Select the Create rule button.

Manage Threat Analytics email notifications

To view, add or edit Threat Analytics email notification settings for your organization, follow these steps:

In the navigation pane, select Settings, and then select Microsoft Defender XDR. Then, select Email notifications.

Next, select Threat Analytics

To add a new notification:

Select Create a notification rule.

Enter a name and description, then next.

Select threat analytics criteria, then next.

Enter the recipients email address, then next.

Select the Create rule button.